

CYB-044 : Initiation à un SOC (Security Operations Center)

Introduction Générale du Cours

Dans le paysage de la cybersécurité moderne, la question n'est plus de savoir si une organisation sera attaquée, mais quand. Face à cette réalité, les entreprises et les institutions ont dû se doter de capacités de détection et de réponse permanentes, disponibles vingt-quatre heures sur vingt-quatre, sept jours sur sept. C'est précisément la mission du Security Operations Center — le SOC — : une organisation, un ensemble de processus et une suite d'outils qui constituent le centre nerveux de la cyberdéfense opérationnelle.

Le SOC n'est pas un simple centre de supervision technique. C'est une entité vivante qui combine des compétences humaines pointues, des technologies de détection avancées et des processus éprouvés pour surveiller en continu l'état de sécurité d'un système d'information, détecter les menaces, y répondre efficacement et améliorer en permanence les capacités défensives de l'organisation.

Ce cours propose une initiation complète au monde du SOC : sa structure organisationnelle et ses modèles de déploiement, les rôles et responsabilités de chaque acteur, l'écosystème d'outils qui le compose (SIEM, SOAR, EDR, threat intelligence), les processus de gestion des alertes et des incidents, et les indicateurs qui permettent de mesurer son efficacité. L'objectif est de vous donner les clés pour comprendre le fonctionnement d'un SOC réel et d'y prendre votre place en tant qu'analyste.

Objectifs Pédagogiques du Module

À l'issue de ce cours, l'apprenant doit être capable de :

1. Maîtrise Conceptuelle et Organisationnelle

- Comprendre le rôle stratégique d'un SOC dans une organisation et ses différents modèles (interne, externalisé, hybride).
- Distinguer les niveaux d'analystes (N1, N2, N3) et leurs responsabilités respectives.
- Identifier les interactions entre le SOC et les autres entités de l'organisation (DSI, RSSI, équipes IT, direction).

2. Compétences Techniques et Opérationnelles

- Décrire les outils constitutifs d'un SOC moderne : SIEM, SOAR, EDR, threat intelligence, case management.
- Comprendre le fonctionnement d'un SIEM et la logique de création des règles de corrélation.
- Appliquer un processus structuré de gestion des alertes, du triage à la clôture de l'incident.

3. Expertise en Réponse à Incident

- Décrire les phases d'un cycle de réponse à incident (détection, triage, investigation, containment, éradication, recovery, post-mortem).
- Utiliser le framework MITRE ATT&CK pour contextualiser les alertes et identifier les tactiques d'attaque.
- Rédiger un rapport d'incident structuré et exploitable par les équipes techniques et la direction.

4. Conformité et Amélioration Continue

- Définir et suivre les KPIs d'un SOC (MTTD, MTTA, MTTR, taux de faux positifs).
- Comprendre l'importance des playbooks et de la documentation dans la standardisation des réponses.

Chapitre 1 : Qu'est-ce qu'un SOC ?

Définition et Enjeux

1. Définition et Mission Fondamentale

Un Security Operations Center (SOC) est une unité organisationnelle — physique ou virtuelle — dédiée à la surveillance continue, à la détection, à l'analyse et à la réponse aux incidents de cybersécurité au sein d'une organisation. Sa mission première est de réduire le temps entre la survenue d'un incident et sa détection (MTTD), puis entre la détection et la réponse (MTTR), afin de limiter l'impact des cyberattaques sur les activités de l'organisation.

Le SOC opère en continu, généralement en mode 24/7/365, car les attaques ne respectent ni les horaires de bureau ni les jours fériés. Cette disponibilité permanente est l'une des caractéristiques fondamentales qui distingue un SOC d'une simple équipe de sécurité IT traditionnelle. Elle implique une organisation en équipes tournantes, une standardisation rigoureuse des processus (pour assurer la continuité entre les équipes) et des outils capables d'alerter automatiquement les analystes en cas d'événement critique.

2. Historique et Évolution du SOC

Les premiers SOC sont apparus dans les années 1990, principalement dans les grandes entreprises et les administrations américaines, sous l'impulsion des premières réglementations sur la sécurité des systèmes d'information. À cette époque, le SOC se résumait essentiellement à la supervision des journaux de pare-feu et des systèmes de détection d'intrusion (IDS), avec des équipes réduites et des outils peu intégrés.

La sophistication croissante des attaques dans les années 2000 (APT, botnets, campagnes de phishing ciblées) a conduit à une transformation profonde du SOC. L'émergence des plateformes SIEM au milieu des années 2000 a permis de centraliser et de corrélérer les événements issus de sources multiples, donnant aux analystes une vision unifiée du SI. La décennie 2010 a vu l'apparition des solutions EDR, des plateformes SOAR et des flux de threat intelligence, faisant du SOC un écosystème technologique complexe intégré.

Aujourd'hui, le SOC intègre de plus en plus l'intelligence artificielle et le machine learning pour automatiser le triage et améliorer la détection des comportements anormaux.

3. Le SOC dans l'Écosystème de Sécurité de l'Organisation

Le SOC n'est pas une entité isolée. Il s'inscrit dans un écosystème de sécurité plus large et interagit avec plusieurs acteurs de l'organisation. Le RSSI (Responsable de la Sécurité des Systèmes d'Information) fixe la stratégie et les objectifs de sécurité ; le SOC en est le bras opérationnel. La DSI fournit l'infrastructure et les accès nécessaires à la supervision ; le SOC remonte les incidents et les vulnérabilités détectées. Les équipes métier sont à la fois les utilisateurs finaux protégés par le SOC et des sources d'information précieuses sur les comportements normaux attendus.

Le SOC entretient également des relations avec des entités externes : les CERT (Computer Emergency Response Team) nationaux comme le CERT-FR de l'ANSSI, les fournisseurs de threat intelligence, les éditeurs de solutions de sécurité et, lors d'incidents majeurs, les équipes de réponse à incident externes (CSIRT privés) ou les autorités (ANSSI, CNIL, autorités judiciaires selon la nature de l'incident).

Chapitre 2 : Structure et Modèles d'un SOC

1. Les Modèles de Déploiement d'un SOC

Il n'existe pas un modèle unique de SOC. Les organisations choisissent leur modèle en fonction de leur taille, de leurs contraintes budgétaires, de leur secteur d'activité et de leur niveau de maturité en cybersécurité. Le tableau suivant présente les quatre principaux modèles rencontrés en entreprise :

Modèle	Description	Avantages	Inconvénients
SOC interne	Équipe dédiée au sein de l'organisation	Maîtrise totale, connaissance du SI, réactivité	Coût élevé, recrutement difficile, couverture 24/7 complexe
SOC externalisé (MSSP)	Service délégué à un prestataire spécialisé	Expertise immédiate, disponibilité 24/7, coût mutualisé	Dépendance au prestataire, moins de connaissance du SI client
SOC hybride	Combinaison interne (pilotage) + externe (opérations N1/N2)	Équilibre coût / maîtrise, flexibilité	Coordination nécessaire, gouvernance plus complexe

Virtual SOC	Analystes distants sans infrastructure physique dédiée	Agilité, faible coût d'infrastructure	Collaboration difficile, dépendance aux outils cloud
-------------	--	---------------------------------------	--

Le choix entre ces modèles n'est pas définitif. Il est courant de voir une organisation commencer par un SOC externalisé pour acquérir de la maturité, puis internaliser progressivement les fonctions les plus sensibles (N2, N3) tout en conservant une couverture externalisée pour le niveau 1. Cette évolution suit naturellement la montée en compétences des équipes internes et la meilleure connaissance du SI.

2. Organisation par Niveaux d'Analystes

Quelle que soit le modèle de déploiement retenu, un SOC est organisé selon une hiérarchie de niveaux d'analystes, chacun ayant des responsabilités et des compétences spécifiques :

Niveau	Rôle	Compétences clés	Activités principales
N1 — Analyste	Triage des alertes	Lecture de logs, connaissance des outils SIEM	Surveillance des tableaux de bord, qualification initiale des alertes, escalade vers N2
N2 — Analyste confirmé	Investigation	Forensique, threat hunting, scripting	Analyse approfondie des incidents, corrélation multi-sources, rédaction des rapports
N3 — Expert / Threat Hunter	Réponse avancée & détection proactive	Reverse engineering, malware analysis, OSINT	Threat hunting, développement de nouvelles règles de détection, support forensique
SOC Manager	Pilotage	Management, reporting, KPIs, conformité	Gestion de l'équipe, reporting direction, amélioration continue des processus

Cette organisation pyramidale garantit l'efficacité opérationnelle : les analystes N1, plus nombreux, traitent le volume d'alertes en continu, tandis que les N2 et N3, plus rares et plus spécialisés, concentrent leur expertise sur les cas les plus complexes. La qualité du processus d'escalade — les critères qui déclenchent le passage d'un niveau à l'autre — est déterminante pour l'efficacité globale du SOC.

3. Les Autres Rôles du SOC

Au-delà de la hiérarchie d'analystes, plusieurs rôles spécialisés contribuent au fonctionnement d'un SOC mature. L'ingénieur SOC (SOC Engineer) est responsable de la maintenance et de l'évolution de l'infrastructure technique : déploiement et configuration des outils, développement des connecteurs d'ingestion de logs, optimisation des performances du SIEM. Son rôle est en coulisses mais fondamental — un SIEM mal configuré ou une ingestion de logs défectueuse peuvent rendre aveugle l'ensemble de l'équipe.

Le Threat Intelligence Analyst est spécialisé dans la collecte, l'analyse et la diffusion de renseignements sur les menaces. Il surveille les forums du dark web, les bulletins des CERT, les rapports des éditeurs de sécurité et les bases d'IOC pour alimenter le SOC en informations contextuelles sur les campagnes d'attaque en cours. Le Forensics Analyst

intervient en support lors d'incidents majeurs nécessitant une analyse approfondie des systèmes compromis, avec des techniques de préservation des preuves et d'analyse de la mémoire vive ou des disques.

Chapitre 3 : L'Écosystème Technologique du SOC

1. Vue d'Ensemble des Outils

Un SOC moderne s'appuie sur un écosystème d'outils complémentaires et intégrés. Chaque catégorie d'outils adresse une fonction spécifique du cycle de détection et de réponse. Le tableau suivant présente les principales catégories et les solutions les plus répandues :

Catégorie	Exemples d'outils	Rôle dans le SOC
SIEM	Splunk, Microsoft Sentinel, IBM QRadar, Elastic SIEM	Collecte, corrélation et alerte sur les événements de sécurité
SOAR	Palo Alto XSOAR, Splunk SOAR, TheHive + Cortex	Automatisation des réponses et orchestration des workflows d'incident
EDR	CrowdStrike Falcon, SentinelOne, Microsoft Defender for Endpoint	Détection et réponse sur les endpoints (postes, serveurs)
Threat Intelligence	MISP, AlienVault OTX, Recorded Future, VirusTotal	Enrichissement des alertes avec des IOC et contexte sur les menaces
Ticketing / Case Management	TheHive, Jira, ServiceNow, RTIR	Suivi du cycle de vie des incidents et traçabilité des actions
Forensique	Volatility, Autopsy, FTK, KAPE	Analyse post-incident des systèmes compromis
Threat Hunting	YARA, Sigma, OSQuery, Elastic EQL	Recherche proactive de menaces non détectées dans le SI

2. Le SIEM — Cœur Technologique du SOC

Le SIEM (Security Information and Event Management) est la pièce maîtresse de tout SOC. Il remplit deux fonctions fondamentales : la collecte et la normalisation des événements de sécurité issus de l'ensemble du SI (Security Information Management — SIM), et la corrélation en temps réel de ces événements pour détecter des patterns d'attaque et générer des alertes (Security Event Management — SEM). C'est sur l'écran du SIEM que l'analyste N1 passe l'essentiel de ses heures de travail.

Un SIEM ingère des événements depuis des centaines ou des milliers de sources : pare-feu, serveurs, postes de travail, applications, équipements réseau, solutions cloud. Ces événements sont normalisés (transformés en un format commun), enrichis (avec des données de contexte comme la géolocalisation des IP ou la criticité des actifs) et indexés pour permettre une recherche instantanée. Les règles de corrélation définies par l'équipe SOC sont appliquées en temps réel sur ce flux d'événements pour identifier les comportements suspects.

Les solutions SIEM du marché se distinguent par leur modèle de déploiement (on-premise, cloud, hybride), leur capacité d'ingestion (en événements par seconde ou en volume de données journalier), leur richesse en règles de corrélation prédéfinies et leur facilité d'intégration avec les autres outils du SOC. Splunk domine le marché des grandes entreprises avec sa puissance de recherche et son écosystème d'applications. Microsoft Sentinel s'impose dans les environnements Microsoft Azure grâce à son intégration native avec Microsoft 365 et Azure AD. Elastic SIEM, basé sur l'ELK Stack, est très apprécié pour sa flexibilité et son modèle open source.

3. Le SOAR — Automatisation et Orchestration

Le SOAR (Security Orchestration, Automation and Response) représente l'évolution naturelle du SIEM : si ce dernier détecte et alerte, le SOAR orchestre et automatise la réponse. Face à des volumes d'alertes croissants et à des équipes SOC sous pression, l'automatisation est devenue indispensable pour maintenir un niveau de réponse acceptable sans augmenter les effectifs proportionnellement.

Un SOAR s'appuie sur des playbooks — des workflows automatisés qui définissent la séquence d'actions à exécuter lors de la détection d'un type d'incident spécifique. Un playbook de réponse au phishing peut, par exemple, automatiquement extraire les URLs et les pièces jointes de l'email signalé, les soumettre à VirusTotal pour analyse, vérifier dans le SIEM si d'autres utilisateurs ont reçu le même email, isoler le poste de l'utilisateur ayant cliqué via l'EDR, et créer un ticket d'incident pré-rempli avec toutes ces informations — le tout en quelques secondes, sans intervention humaine. L'analyste n'intervient qu'à l'étape de validation finale.

4. L'EDR — Visibilité sur les Endpoints

L'EDR (Endpoint Detection and Response) est déployé sur chaque poste de travail et serveur pour collecter en continu des données comportementales : processus créés, fichiers modifiés, connexions réseau initiées, clés de registre accédées. Ces données sont transmises en temps réel à une console centrale qui applique des règles de détection et des modèles comportementaux pour identifier les activités malveillantes.

L'EDR offre des capacités que le SIEM seul ne peut pas fournir : la visibilité au niveau du processus (quel exécutable a initié quelle connexion réseau), la détection de techniques d'attaque fileless (qui n'écrivent pas de fichier sur le disque et échappent aux antivirus traditionnels), et la capacité de réponse directe depuis la console (isolation réseau du poste, kill de processus, collecte d'artefacts forensiques à distance). Dans le SOC, les alertes EDR sont parmi les plus riches en contexte et constituent souvent le point de départ des investigations N2.

5. La Threat Intelligence — Contextualiser les Menaces

La threat intelligence (renseignement sur les menaces) consiste à collecter, analyser et exploiter des informations sur les acteurs malveillants, leurs méthodes et leurs indicateurs de compromission, afin d'améliorer la détection et d'anticiper les attaques. Elle se décline en plusieurs niveaux de maturité : la threat intelligence tactique (IOC : IP, domaines, hashes malveillants à bloquer), la threat intelligence opérationnelle (TTP des groupes d'attaquants, campagnes en cours), et la threat intelligence stratégique (évolution des menaces, secteurs ciblés, évaluations géopolitiques).

Dans le SOC, la threat intelligence s'intègre au SIEM pour enrichir automatiquement les événements (une alerte sur une connexion vers une IP répertoriée dans une liste de commande et contrôle est beaucoup plus significative qu'une simple connexion vers une IP inconnue) et alimenter les listes de blocage du pare-feu. Des plateformes comme MISP (Malware Information Sharing Platform) permettent de partager des IOC entre organisations et de consommer des flux de threat intelligence externes.

Chapitre 4 : Processus de Gestion des Alertes

1. Le Cycle de Vie d'une Alerte

Toute alerte générée par le SIEM ou un autre outil de détection suit un cycle de vie structuré, du déclenchement à la clôture. Ce cycle est formalisé dans les processus du SOC pour garantir qu'aucune alerte n'est perdue, que les actions sont tracées et que les incidents sont traités avec la diligence appropriée à leur niveau de criticité. Le tableau suivant détaille les étapes de ce processus :

Étape	Action	Responsable	Outils / Livrables
1	Réception de l'alerte SIEM	Analyste N1	Dashboard SIEM — alerte déclenchée
2	Triage initial : vrai positif ou faux positif ?	Analyste N1	Consultation des logs sources, CMDB, threat intel
3	Escalade si vrai positif confirmé	Analyste N1 → N2	Ticket d'incident créé dans TheHive / Jira
4	Investigation approfondie	Analyste N2	Rapport d'analyse, timeline, IOC identifiés
5	Containment — isolation de la menace	N2 / N3 + Équipe IT	Blocage pare-feu, isolation réseau, désactivation compte
6	Éradication et Recovery	Équipe IT + N2	Nettoyage système, restauration, patch
7	Post-mortem et clôture	N2 + SOC Manager	Rapport de clôture, mise à jour des règles, REX

2. Le Triage — Première Ligne de Défense

Le triage est la compétence fondamentale de l'analyste N1. Il consiste à qualifier rapidement une alerte reçue du SIEM en répondant à deux questions essentielles : cette alerte correspond-elle à un événement réel ou est-ce un faux positif ? Si c'est un événement réel, quelle est sa criticité et nécessite-t-il une escalade immédiate ?

Pour qualifier une alerte, l'analyste N1 consulte plusieurs sources complémentaires. Les logs sources bruts permettent de vérifier le contexte précis de l'événement déclencheur. La CMDB (Configuration Management Database) renseigne sur la nature de l'actif concerné (serveur critique, poste utilisateur, machine de test). L'historique de l'alerte dans le SIEM permet d'évaluer si ce pattern a déjà été observé et comment il a été traité. Enfin, les flux de threat intelligence permettent de vérifier si les IP ou domaines impliqués sont connus comme malveillants.

La décision de triage doit être prise rapidement — idéalement en moins de 15 minutes pour les alertes de criticité haute — et documentée dans l'outil de ticketing, qu'elle débouche sur une clôture (faux positif documenté) ou une escalade. La traçabilité de toutes les décisions de triage est essentielle, non seulement pour la conformité, mais aussi pour améliorer la qualité des règles de détection au fil du temps.

3. L'Investigation — Reconstruction de la Chronologie

L'investigation, conduite par l'analyste N2, vise à comprendre la nature complète de l'incident : comment l'attaquant est entré dans le SI, quelles actions il a réalisées, quels systèmes sont compromis, quelles données ont pu être exfiltrées. Cette phase repose sur la collecte et l'analyse de preuves numériques issues de multiples sources.

L'outil central de l'investigation est la timeline — une chronologie des événements reconstituée à partir des logs. L'analyste N2 recherche dans le SIEM et les logs bruts tous les événements associés à l'incident (même source IP, même compte utilisateur, même machine) dans une fenêtre temporelle étendue, pour remonter aux origines de l'attaque. Cette reconstruction est guidée par le framework MITRE ATT&CK, qui permet de mapper chaque action observée sur une technique d'attaque connue et d'anticiper les étapes suivantes selon le mode opératoire de l'attaquant.

4. Le Containment et la Réponse

Le containment est la phase critique où le SOC passe de l'observation à l'action. Son objectif est d'empêcher la propagation de la menace sans nécessairement éliminer immédiatement l'attaquant — une isolation trop brutale peut en effet alerter l'adversaire et lui faire effacer ses traces. Les actions de containment typiques incluent l'isolation réseau d'une machine compromise via l'EDR (la machine est déconnectée du réseau mais reste joignable par l'équipe SOC pour les investigations), le blocage d'une adresse IP malveillante sur le pare-feu, la désactivation d'un compte utilisateur compromis dans l'Active Directory, ou la révocation d'un token d'accès dans une application cloud.

La décision de containment doit toujours être prise en concertation avec les équipes IT et les responsables métier, car elle peut avoir un impact sur la disponibilité des services. Un serveur de production isolé en pleine nuit peut interrompre des processus critiques. Cette

tension entre impératifs de sécurité et continuité d'activité est l'un des défis les plus délicats de la gestion d'incident, et elle illustre pourquoi le SOC Manager doit avoir une vision à la fois technique et business.

Chapitre 5 : Le Framework MITRE ATT&CK

1. Présentation et Structure

MITRE ATT&CK (Adversarial Tactics, Techniques and Common Knowledge) est une matrice de référence mondiale décrivant les comportements des attaquants informatiques. Publiée et maintenue gratuitement par l'organisation américaine MITRE, elle est aujourd'hui adoptée par la quasi-totalité des SOC comme langage commun pour décrire, détecter et répondre aux cybermenaces.

La matrice ATT&CK s'organise en deux dimensions. Les colonnes représentent les tactiques — les objectifs intermédiaires que l'attaquant cherche à atteindre au cours de son attaque (Reconnaissance, Accès initial, Exécution, Persistance, Escalade de privilèges, Évasion des défenses, Accès aux identifiants, Découverte, Déplacement latéral, Collecte, Exfiltration, Impact). Les cellules représentent les techniques — les méthodes concrètes utilisées pour atteindre chaque tactique (par exemple, sous la tactique Accès initial : Spearphishing Attachment, Exploitation d'une application exposée, Valid Accounts...). Chaque technique est documentée avec sa description, ses exemples d'utilisation par des groupes d'attaquants connus, les sources de données permettant de la détecter et les mesures d'atténuation possibles.

2. Utilisation dans le SOC

ATT&CK est utilisé dans le SOC à trois niveaux distincts. Pour la détection, les règles de corrélation du SIEM sont mappées sur des techniques ATT&CK : cela permet de visualiser sur la matrice quelles techniques sont couvertes par les règles existantes et d'identifier les angles morts — les techniques pour lesquelles le SOC n'a pas encore de détection. Cette visualisation, souvent appelée « heat map ATT&CK », est un outil puissant pour planifier les développements futurs des capacités de détection.

Pour l'investigation, lorsqu'un analyste N2 identifie un comportement suspect, il le mappe sur la technique ATT&CK correspondante. Cela lui permet immédiatement de comprendre dans quel contexte d'attaque se situe l'événement observé, quelles autres techniques l'attaquant est susceptible d'avoir utilisées ou d'utiliser prochainement (selon les groupes d'attaquants connus pour cette technique), et quelles sources de logs consulter pour rechercher des preuves complémentaires. Pour le reporting enfin, ATT&CK fournit un vocabulaire standardisé qui permet de communiquer sur les incidents de manière précise et compréhensible par tous les acteurs de la communauté cybersécurité.

3. Les Groupes d'Attaquants et les Campagnes

MITRE ATT&CK référence également des groupes d'attaquants connus (aussi appelés threat actors ou APT — Advanced Persistent Threats), identifiés par des noms de code comme APT28 (groupe russe lié au renseignement militaire, aussi connu sous le nom Fancy Bear), APT41 (groupe chinois mêlant espionnage étatique et cybercriminalité), ou Lazarus Group (acteur nord-coréen impliqué dans des attaques financières et des sabotages). Pour chaque groupe, ATT&CK documente les techniques qu'il utilise préférentiellement, ses cibles habituelles et ses campagnes connues.

Cette information est précieuse pour le SOC dans une approche dite de « threat-informed defense » : si le secteur de l'organisation correspond aux cibles habituelles d'un groupe spécifique, le SOC peut prioriser le développement de détections couvrant les techniques préférées de ce groupe, plutôt que de chercher à couvrir exhaustivement l'ensemble de la matrice.

Chapitre 6 : Playbooks et Gestion des Incidents

1. Qu'est-ce qu'un Playbook ?

Un playbook est une procédure documentée et standardisée décrivant, étape par étape, comment répondre à un type d'incident de sécurité spécifique. Il est l'équivalent en cybersécurité du protocole médical d'urgence : face à une situation critique, l'analyste ne doit pas réfléchir à ce qu'il faut faire — il doit exécuter une procédure éprouvée, rapidement et sans oublier d'étapes. Les playbooks garantissent la cohérence des réponses entre analystes et entre équipes (une alerte traitée à 3h du matin par un analyste N1 junior doit être traitée de la même manière qu'à 10h du matin par un analyste confirmé).

Chaque type d'incident courant doit disposer de son playbook dédié : phishing reçu par un utilisateur, ransomware détecté sur un poste, intrusion via un compte compromis, DDoS sur une infrastructure exposée, fuite de données détectée par le DLP, scan de vulnérabilités interne anormal. Ces playbooks sont rédigés par les analystes N2/N3 en collaboration avec le SOC Manager, validés par le RSSI, et révisés régulièrement à la lumière des incidents traités et des retours d'expérience.

2. Structure d'un Playbook Efficace

Un playbook bien structuré comprend plusieurs sections indispensables. La section de déclenchement précise les conditions exactes qui déclenchent l'application du playbook : quel type d'alerte, depuis quelle source, avec quels critères de criticité. Cette précision évite les ambiguïtés et garantit que le bon playbook est appliqué dans la bonne situation.

La section d'investigation détaille les étapes à suivre pour qualifier l'incident et collecter les informations nécessaires : quels logs consulter, quelles requêtes SIEM exécuter, quels systèmes interroger. Elle est suivie de la section de containment qui liste les actions à réaliser pour limiter l'impact, avec les autorisations requises pour chaque action (certaines actions, comme l'isolation d'un serveur de production, nécessitent une validation du SOC

Manager ou du RSSI). La section de communication précise qui doit être notifié, à quel moment et selon quel format, en interne comme en externe. Enfin, la section de clôture décrit les livrables attendus : rapport d'incident, mise à jour des règles de détection, actions de remédiation à suivre.

3. Rédaction d'un Rapport d'Incident

Le rapport d'incident est le document de référence qui trace l'ensemble du traitement d'un incident, des premières alertes à la clôture. Il sert plusieurs objectifs : traçabilité légale (en cas de procédure judiciaire ou d'audit réglementaire), communication vers la direction (synthèse exécutive de l'impact et des actions réalisées), base de connaissance pour les futures investigations (les incidents documentés sont des sources d'apprentissage précieuses), et déclencheur d'améliorations (les lacunes de détection identifiées donnent lieu à de nouvelles règles SIEM).

Un rapport d'incident complet comporte une synthèse exécutive (1 page, accessible à un non-technicien, résumant l'incident, son impact et les actions réalisées), une chronologie détaillée des événements avec les horodatages précis, la description technique de l'attaque avec le mapping ATT&CK des techniques observées, la liste des systèmes et données affectés, les actions de réponse réalisées, et les recommandations pour prévenir la récurrence. Ce rapport est rédigé par l'analyste N2 en charge de l'investigation et revu par le SOC Manager avant diffusion.

Chapitre 7 : Mesure de la Performance du SOC

1. Pourquoi Mesurer la Performance ?

Un SOC sans indicateurs de performance est un SOC dont on ne peut pas évaluer l'efficacité réelle — ni justifier les investissements auprès de la direction, ni identifier les axes d'amélioration. La mesure de la performance répond à deux besoins distincts : le pilotage opérationnel (suivre en temps réel l'activité de l'équipe et détecter les dérives) et le reporting stratégique (rendre compte à la direction du niveau de protection fourni et de l'évolution de la posture de sécurité).

Les KPIs d'un SOC doivent être SMART : spécifiques (mesurer un aspect précis et non ambigu), mesurables (calculables à partir de données disponibles dans les outils), atteignables (réalistes compte tenu des ressources), pertinents (alignés sur les objectifs de sécurité de l'organisation) et temporellement définis (calculés sur une période fixe et comparables dans le temps).

2. Les KPIs Fondamentaux du SOC

Le tableau suivant présente les indicateurs clés de performance les plus utilisés dans les SOC, avec leurs définitions et les objectifs cibles généralement visés :

KPI	Définition	Objectif cible
MTTD (Mean Time to Detect)	Délai moyen entre le début d'un incident et sa détection par le SOC	< 1 heure (incidents critiques)
MTTA (Mean Time to Acknowledge)	Délai entre la génération d'une alerte et sa prise en charge par un analyste	< 15 minutes
MTTR (Mean Time to Respond)	Délai entre la détection et l'application des premières mesures de containment	< 4 heures (critiques)
Taux de faux positifs	Proportion d'alertes ne correspondant pas à un incident réel	< 10 %
Taux de couverture MITRE ATT&CK	Pourcentage des techniques ATT&CK couvertes par les règles de détection	> 60 % (objectif progressif)
Nombre d'incidents clos / semaine	Volume d'incidents traités et clôturés par l'équipe SOC	À établir selon la taille du SI
Taux de réouverture d'incidents	Incidents clôturés nécessitant une réouverture (résolution incomplète)	< 5 %

3. La Couverture ATT&CK comme KPI Stratégique

Au-delà des KPIs opérationnels (temps de réponse, volume d'incidents), un indicateur stratégique prend de plus en plus d'importance : le taux de couverture de la matrice MITRE ATT&CK. Il mesure le pourcentage des techniques ATT&CK pour lesquelles le SOC dispose d'au moins une règle de détection active. Un SOC débutant couvrira typiquement 20 à 30 % de la matrice, un SOC mature visera 60 % et au-delà.

Cet indicateur est particulièrement parlant pour la direction car il traduit le niveau de couverture des menaces en termes compréhensibles : « nous détectons 45 % des techniques d'attaque documentées, voici notre plan pour atteindre 60 % dans les 12 prochains mois ». Il guide également les priorités de développement des règles de détection en ciblant les techniques les plus fréquemment utilisées par les groupes d'attaquants ciblant le secteur de l'organisation.

4. Tableau de Bord et Reporting Direction

Le SOC Manager produit généralement deux niveaux de reporting. Le tableau de bord opérationnel, mis à jour en temps réel ou quotidiennement, est destiné à l'équipe SOC : il affiche le volume d'alertes en cours, les incidents ouverts par criticité, les KPIs de la semaine et les tendances. Il est l'écran de pilotage quotidien de l'activité SOC.

Le rapport mensuel de sécurité, destiné au RSSI et à la direction, synthétise l'activité du SOC sur le mois écoulé : nombre d'incidents traités par criticité, évolution des KPIs, principaux incidents du mois avec leur impact, nouveaux risques détectés, et plan d'action

pour le mois suivant. Ce rapport est un outil de gouvernance essentiel qui permet à la direction de prendre des décisions éclairées sur les investissements en sécurité.

Chapitre 8 : Cas Pratique — Mise en Situation SOC

1. Présentation du Scénario

Nous sommes le mardi 14 novembre, 02h17. L'analyste N1 de permanence nuit dans le SOC de FinanceCorp SA — une société de services financiers de 800 salariés — reçoit une alerte SIEM de criticité haute. La règle déclenchée s'intitule « Authentification réussie après plusieurs échecs — Compte à privilèges — Hors horaires ». Les détails de l'alerte indiquent : 15 échecs d'authentification RDP sur le compte « svc_backup » (compte de service utilisé pour les sauvegardes), suivis d'une authentification réussie depuis l'adresse IP 45.33.32.156, à 02h14. Le serveur cible est « SRV-BACKUP-01 », qualifié comme actif critique dans la CMDB.

L'analyste N1 dispose de 15 minutes pour réaliser le triage initial et décider d'escalader ou non vers le N2 de permanence.

2. Phase de Triage N1

L'analyste commence par vérifier l'IP source 45.33.32.156 dans les flux de threat intelligence intégrés au SIEM. Résultat : cette IP est répertoriée dans plusieurs listes noires comme appartenant à un fournisseur de VPN commercial (Mullvad VPN), souvent utilisé pour masquer l'origine géographique réelle des connexions. Ce n'est pas une IP de commande et contrôle connue, mais son caractère anonymisant est un signal d'alerte supplémentaire.

Il vérifie ensuite dans l'Active Directory : le compte svc_backup n'est normalement jamais utilisé de manière interactive — il est configuré pour des connexions automatisées de service uniquement, et son dernier usage interactif remonte à plus de 6 mois. Les 15 échecs d'authentification en 3 minutes depuis la même IP externe constituent un pattern de brute force caractérisé. La combinaison compte de service à privilèges + brute force réussi + IP anonymisante + heure nocturne + serveur critique justifie une escalade immédiate. L'analyste ouvre un ticket de criticité critique dans TheHive et contacte le N2 de permanence à 02h21.

3. Phase d'Investigation N2

L'analyste N2 prend en charge l'incident à 02h24. Il étend la recherche dans le SIEM aux 2 heures précédant l'alerte pour cartographier l'activité complète du compte svc_backup et de l'IP 45.33.32.156. Il découvre que cette même IP a effectué des tentatives de connexion sur 3 autres serveurs (SRV-AD-01, SRV-FILE-01, SRV-ERP-01) dans les 30 minutes précédentes — toutes en échec. Le compte svc_backup, une fois connecté à SRV-BACKUP-01, a exécuté plusieurs commandes PowerShell (détectées par l'EDR) : net

user, net localgroup administrators, et whoami /all — des commandes de découverte post-exploitation classiques, mappées sur la technique ATT&CK T1087 (Account Discovery) et T1069 (Permission Groups Discovery).

La situation est claire : un attaquant a réussi à compromettre le mot de passe du compte de service svc_backup (probablement via une attaque par dictionnaire) et est en phase de reconnaissance post-accès initial sur le serveur de sauvegarde. Le risque d'exfiltration ou de chiffrement des sauvegardes est élevé. À 02h31, le N2 prononce le containment.

4. Containment, Résolution et Post-Mortem

Les actions de containment sont exécutées en concertation avec l'astreinte IT : le compte svc_backup est désactivé dans l'Active Directory, SRV-BACKUP-01 est isolé via l'EDR (déconnecté du réseau, accessible uniquement par le SOC), l'IP 45.33.32.156 est bloquée sur le pare-feu périmétrique, et une alerte est levée pour vérifier l'intégrité des autres comptes de service. À 03h15, le périmètre est contenu. Aucune exfiltration de données n'est détectée dans les logs réseau. L'incident est classifié comme intrusion détectée — containment réussi.

Le post-mortem, réalisé le lendemain en équipe, révèle la cause racine : le mot de passe du compte svc_backup n'avait pas été changé depuis 3 ans et ne respectait pas la politique de complexité (8 caractères, sans caractères spéciaux). Trois actions correctrices sont décidées : rotation immédiate de tous les mots de passe des comptes de service, déploiement d'une règle d'alerte spécifique sur les connexions interactives des comptes de service, et vérification de la configuration du pare-feu pour bloquer les connexions RDP directes depuis Internet. Le délai entre l'alerte et le containment a été de 17 minutes — en deçà de l'objectif de 30 minutes fixé par le SOC.

Synthèse Générale du Module

Ce cours vous a conduit depuis la définition fondamentale du SOC jusqu'à la mise en situation concrète d'un incident traité en conditions réelles. La progression adoptée reflète la réalité du terrain : comprendre l'organisation avant de maîtriser les outils, maîtriser les outils avant d'appliquer les processus, appliquer les processus avant de mesurer et d'améliorer.

Trois grandes leçons synthétisent l'ensemble du cours. La première est que le SOC est avant tout une organisation humaine. Les outils — SIEM, SOAR, EDR — ne sont que des amplificateurs des compétences humaines. Un SIEM mal configuré ou une équipe sans processus formalisés ne protège pas l'organisation ; une équipe compétente et bien organisée, même avec des outils modestes, peut atteindre un niveau de protection remarquable. Le facteur humain — recrutement, formation, gestion des compétences, prévention de l'épuisement professionnel (le burn-out des analystes SOC est un problème documenté du secteur) — est la priorité numéro un du SOC Manager.

La deuxième leçon est que la standardisation des processus est le socle de l'efficacité opérationnelle. Les playbooks, les procédures de triage, les templates de rapport d'incident ne sont pas de la bureaucratie : ils sont la garantie que chaque incident est traité de manière

cohérente, que les décisions de containment sont prises avec les bonnes informations, et que les leçons apprises d'un incident bénéficient à l'ensemble de l'équipe.

La troisième leçon est que le SOC est un investissement dont la valeur se mesure à l'aune des incidents qu'il a permis de détecter et de contenir avant qu'ils ne se transforment en catastrophes. Le ROI de la cybersécurité est difficile à mesurer en termes positifs — on ne peut pas facilement quantifier les attaques qui n'ont pas eu lieu. Mais le coût d'un incident non détecté — rançon, fuite de données, atteinte à la réputation, sanctions réglementaires — est lui très concret et souvent bien supérieur au coût de fonctionnement d'un SOC sur plusieurs années.

Glossaire

Terme	Définition
ATT&CK (MITRE)	Matrice de référence des tactiques, techniques et procédures (TTP) utilisées par les attaquants, publiée et maintenue par MITRE.
Containment	Phase de réponse à incident visant à limiter la propagation de la menace sans nécessairement l'éliminer immédiatement.
EDR	Endpoint Detection and Response — solution de sécurité déployée sur les postes et serveurs pour détecter et répondre aux menaces en temps réel.
Escalade	Transmission d'une alerte ou d'un incident d'un niveau d'analyste à un niveau supérieur lorsque le traitement dépasse les compétences ou les droits du niveau en charge.
Faux positif	Alerte générée par le SIEM ou un outil de détection qui ne correspond pas à un incident de sécurité réel.
IOC	Indicator of Compromise — observable technique (hash de fichier, adresse IP, domaine, clé de registre) permettant d'identifier une compromission.
Kill Chain	Modèle de décomposition d'une cyberattaque en phases séquentielles (reconnaissance, armement, livraison, exploitation, installation, C&C, actions sur objectifs).
MSSP	Managed Security Service Provider — prestataire qui opère un SOC pour le compte de ses clients, en mode externalisé.
Playbook	Procédure documentée et standardisée décrivant les étapes de réponse à un type d'incident spécifique (ransomware, phishing, intrusion...).
Post-mortem	Analyse réalisée après la clôture d'un incident pour identifier les causes racines, les lacunes de détection et les améliorations à apporter.
SIEM	Security Information and Event Management — plateforme centrale du SOC, assurant la collecte, la corrélation et l'alerte sur les événements de sécurité.
SOAR	Security Orchestration, Automation and Response — plateforme automatisant les workflows de réponse à incident et orchestrant les outils du SOC.
Threat Hunting	Recherche proactive de menaces non détectées par les outils automatisés, basée sur des hypothèses et l'analyse comportementale.
Threat Intelligence	Ensemble des informations contextuelles sur les menaces (acteurs, TTP, IOC) permettant d'anticiper, détecter et répondre aux attaques.
TTP	Tactiques, Techniques et Procédures — description structurée du comportement d'un attaquant, formalisée dans le cadre MITRE ATT&CK.
Triage	Phase initiale de traitement d'une alerte consistant à qualifier rapidement sa nature (vrai ou faux positif) et sa criticité, afin de prioriser la réponse.